ФГБОУ ВО «Московский технологический университет»
Институт кибербезопасности и цифровых технологий

Кафедра КБ-1 «Защита информации»

Дисциплина: «Разработка и эксплуатация автоматизированных систем в защищенном исполнении»

Отчет по лабораторной работе №3

Тема: “Нотация BPMN в построении статической модели области функционирования АСЗИ «как будет» (точка зрения инженера по ЗИ АС)”

Вариант задания №10

Выполнил:
Студент группы БАСО-04-22
Кузнецов Алексей Александрович

Проверил:
доцент Федин Ф.О.

Москва, 2026

Учебная цель занятия: Углубить теоретические знания и выработать практические умения применения инструментального средства Bizagi Modeler для построения модели предметной области «как будет»

Место проведения занятия: компьютерная аудитория.

Учебно-материальное обеспечение:

1) Методическая разработка.

2) Компьютерный класс с ПЭВМ.

3) Bizagi Modeler.

Задание №1. В инструментальном средстве Bizagi Modeler самостоятельно повторить все действия по построению усовершенствованной статической модели защиты процесса продажи товаров в торговой компании «Гамма» (модель «to-be»). Модель должна быть построена с точки зрения сотрудника службы ИБ.

Ход выполнения задания

В результате анализа ранее созданной модели «как есть» были выявлены недостатки делового процесса обслуживания клиентов, рассматриваемого с точки зрения инженера по информационной безопасности. Для устранения выявленных недостатков, выполним совершенствование ранее построенной модели, но для начала перечислим недостатки, обнаруженные в ходе выполнения предыдущей работы:

− вход пользователей в операционные системы рабочих станций своих автоматизированных рабочих мест (АРМ) производится с использованием однофакторной парольной аутентификации, что не обеспечивает надежную защиту ПДн клиентов и сотрудников компании, а также данных по выполняемым заказам. Пользователи, благодаря собственной беспечности, могут применять пароли, которые можно легко угадать или подобрать. Логин и пароль могут быть перехвачены или подсмотрены в процессе ввода. Логин и пароль можно получить от владельца путем его подкупа или шантажа и др.;

− отсутствует единая модель данных организации (база данных), данные по заказам, клиентам и сотрудникам хранятся в файлах офисных приложений (MS Excel, MS Word, Calc, Writer и др.);

− отсутствует возможность организации корректного многопользовательского доступа к данным по заказам, клиентам и сотрудникам;

− коммуникация между сотрудниками компании в процессе их работы над заказами осуществляется посредством электронной почты или

переносных электронных носителей;

− отсутствует разграничение доступа к файловым ресурсам и устройствам. После входа в операционную систему компьютера, пользователь получает неограниченные возможности по работе с данными по заказам, клиентам и сотрудникам компании;

− отсутствует защищенный канал передачи информации между сотрудниками, между менеджером и клиентом;

− персональные данные хранятся на локальных компьютерах сотрудников, создавая угрозу несанкционированного распространения и риск утечки;

− отсутствует механизм сетевого разграничения, когда сотрудник не может заниматься обработкой ПДн при подключении к сетям общего пользования, в том числе Интернет;

− выявлена перегруженность юриста, обусловленная отсутствием автоматизации процесса проверки документов перед их подписанием менеджером и заказчиком.

Для модернизации процесса авторизации в ОС АРМ воспользуемся опытом передовой отечественной ИТ-компании АО “Лаборатория Касперского”, специализирующейся на разработке продуктов обеспечения информационной безопасности.

По опыту компании, использование компьютеров с ОС Windows считается безопасным при реализации в купе с различными средствами защиты информации (например, Kaspersky Endpoint Security, Kaspersky Security Center и другие) и контроллером домена.

Такой подход позволяет обеспечивать безопасность информации на должном уровне без сильного снижения удобства пользования ОС АРМ и без необходимости в переобучении сотрудников для работы с ОС АРМ на базе ядра Linux (таких как, например, Astra Linux), с соответствующими аналогами профессионального ПО UNIX-систем.

Контроллер домена (КД) должен размещаться на выделенном сервере,

расположенном в обособленной серверной комнате, защищенной в соответствии с требованиями по информационной безопасности.

КД обладает следующими функциями:

- производить проверку подлинности пользователей при входе в систему (логин/пароль) и определять их права доступа к ресурсам (файлы, принтеры);

- хранить, создавать, изменять и удалять учетные записи пользователей, групп, компьютеров и других объектов сети;

- централизованно управлять настройками операционных систем, приложений и параметров безопасности для всех компьютеров и пользователей в домене;

- синхронизировать базы данных Active Directory между контроллерами домена для обеспечения актуальности информации и отказоустойчивости;

- взаимодействовать с системой доменных имен (DNS) для поиска контроллеров домена и других сетевых ресурсов;

- вести журналы событий, регистрацию действий пользователей и изменений в конфигурации.

Обновленный процесс авторизации в ОС изображен на рисунке 1.

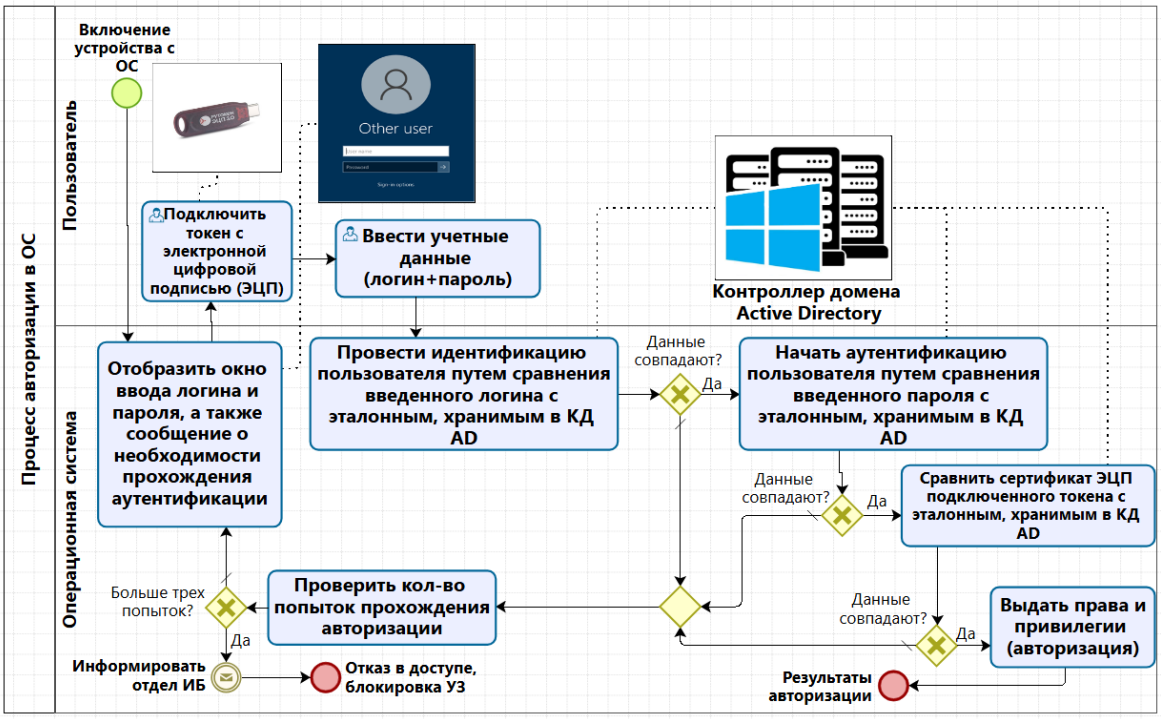


Рисунок 1 – Подпроцесс “Выполнить вход в ОС АРМ”

В соответствии с идеологией новой модели, для работы с данными больше не предполагается использовать файлы офисных приложений, поэтому мы удалим их из модели. Всю информацию по деятельности отдела обработки заказов предполагается сосредоточить в реляционной базе данных автоматизированной системы в защищенном исполнении обработки заказов (БД АСЗИ ОЗ). Такая база данных должна размещаться на выделенном сервере, расположенном в обособленной серверной комнате, защищенной в соответствии с требованиями по информационной безопасности. Для отображения базы данных в нашей модели воспользуемся графическим элементом “Хранилище данных”. Доступ менеджера, специалиста или юриста к базе данных возможен только после прохождения этими сотрудниками процедуры аутентификации и проверки прав пользователя. Для отображения данного факта в модель добавим подпроцесс “Выполнить вход в СУБД”, под которым будет подразумеваться аутентификация и проверка прав пользователя СУБД (рисунок 2).

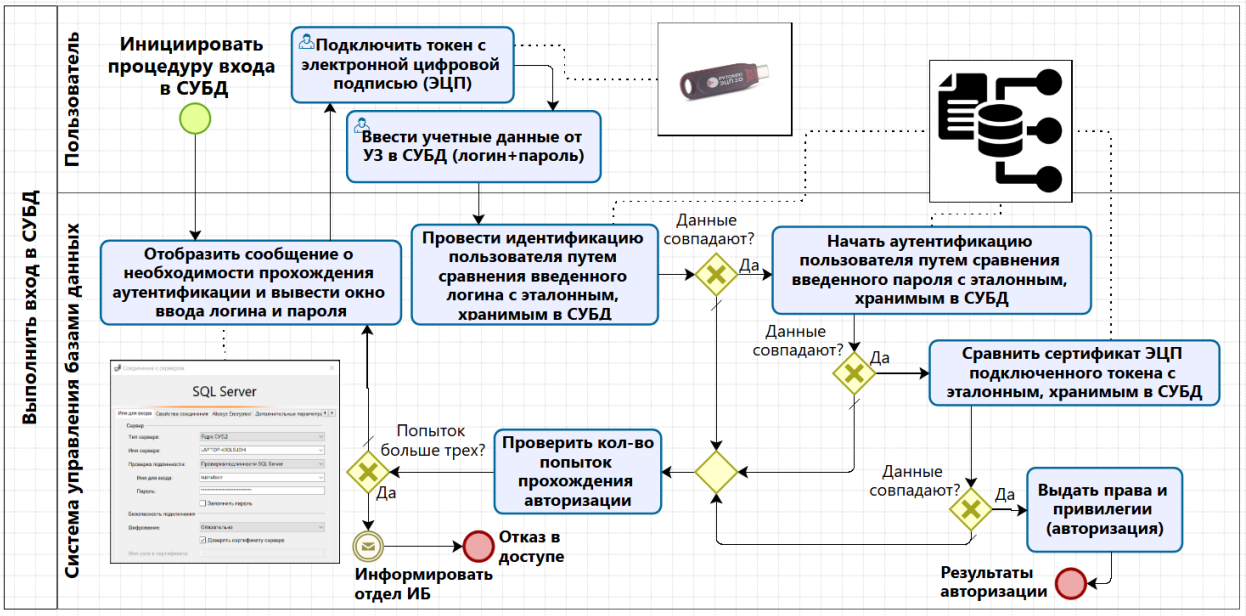


Рисунок 2 – Подпроцесс “Выполнить вход в СУБД”

Созданная модель “как будет” представлена на рисунке 3. Для работы с базой данных в компании предполагается развернуть локальную вычислительную сеть (ЛВС).

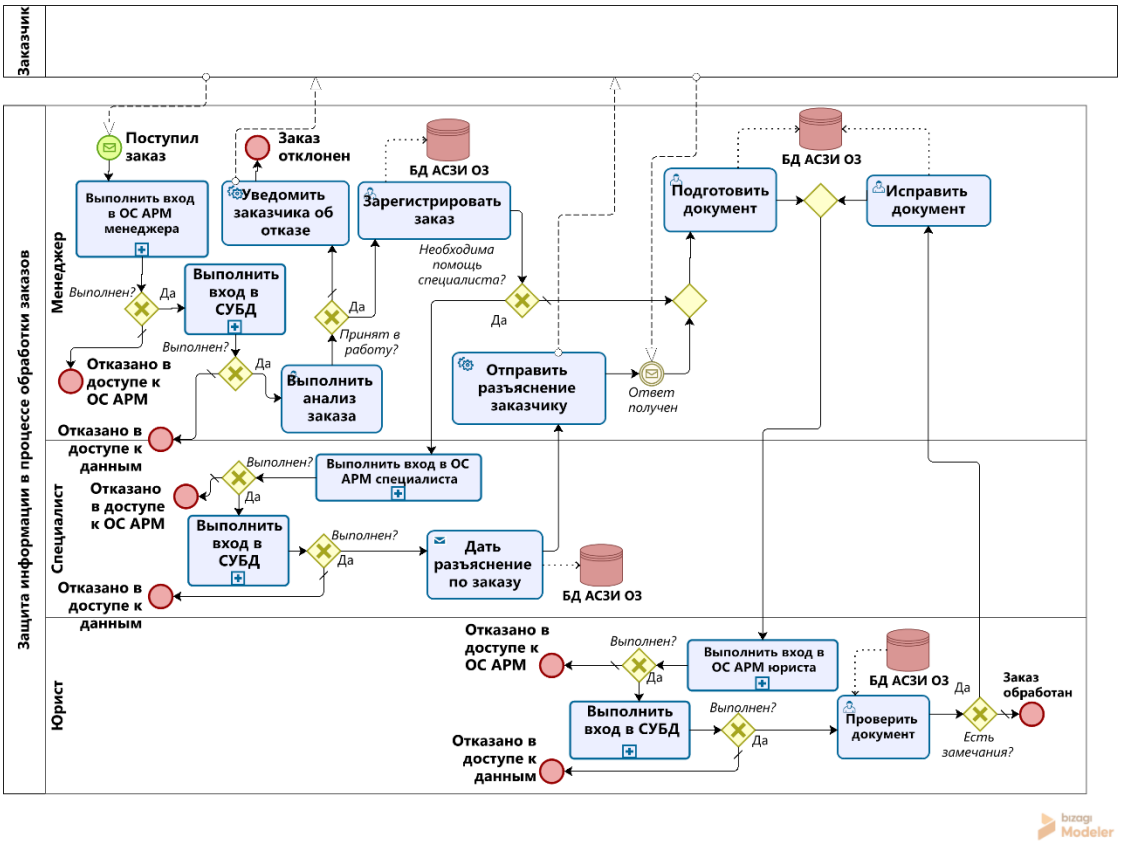


Рисунок 3 – Модель ЗИ “как будет” в процессе продажи товаров

Задание №2. Для предметной области своего варианта, в инструментальном средстве Bizagi Modeler, самостоятельно построить усовершенствованную статическую модель защиты автоматизируемого процесса (модель «to-be»). Модель должна быть построена с точки зрения сотрудника службы ИБ.

Ход выполнения задания

Предметной областью является процесс учета кадров маркетинговой компании. Рассматривается этап трудоустройства уже утвержденного кандидата, начиная с момента принятия положительного решения руководством.

В результате анализа ранее созданной модели «как есть» были выявлены недостатки делового процесса обслуживания клиентов, рассматриваемого с точки зрения инженера по информационной безопасности. Для устранения выявленных недостатков, выполним совершенствование ранее построенной модели, но для начала перечислим недостатки, обнаруженные в ходе выполнения предыдущей работы:

− вход пользователей в операционные системы рабочих станций своих автоматизированных рабочих мест (АРМ) производится с использованием однофакторной парольной аутентификации, что не обеспечивает надежную защиту ПДн клиентов и сотрудников компании, а также данных по выполняемым заказам. Пользователи, благодаря собственной беспечности, могут применять пароли, которые можно легко угадать или подобрать. Логин и пароль могут быть перехвачены или подсмотрены в процессе ввода. Логин и пароль можно получить от владельца путем его подкупа или шантажа и др.;

− отсутствует единая модель данных организации (база данных), данные по заказам, клиентам и сотрудникам хранятся в файлах офисных приложений (MS Excel, MS Word, Calc, Writer и др.);

− коммуникация между сотрудниками компании в процессе их работы

над заказами осуществляется посредством электронной почты или переносных электронных носителей;

− отсутствует разграничение доступа к файловым ресурсам и устройствам. После входа в операционную систему компьютера, пользователь получает неограниченные возможности по работе с данными по заказам, клиентам и сотрудникам компании;

− отсутствует защищенный канал передачи информации между сотрудниками, между менеджером и клиентом;

− персональные данные хранятся на локальных компьютерах сотрудников, создавая угрозу несанкционированного распространения и риск утечки;

− отсутствует механизм сетевого разграничения, когда сотрудник не может заниматься обработкой ПДн при подключении к сетям общего пользования, в том числе Интернет;

Для модернизации процесса авторизации в ОС АРМ воспользуемся опытом передовой отечественной ИТ-компании АО “Лаборатория Касперского”, специализирующейся на разработке продуктов обеспечения информационной безопасности.

По опыту компании, использование компьютеров с ОС Windows считается безопасным при реализации в купе с различными средствами защиты информации (например, Kaspersky Endpoint Security, Kaspersky Security Center и другие) и контроллером домена.

Такой подход позволяет обеспечивать безопасность информации на должном уровне без сильного снижения удобства пользования ОС АРМ и без необходимости в переобучении сотрудников для работы с ОС АРМ на базе ядра Linux (таких как, например, Astra Linux), с соответствующими аналогами профессионального ПО UNIX-систем. Также, внедрение двухфакторной аутентификации сильно увеличивает защиту рабочих станций.

Контроллер домена (КД) должен размещаться на выделенном сервере, расположенном в обособленной серверной комнате, защищенной в

соответствии с требованиями по информационной безопасности.

КД обладает следующими функциями:

- производить проверку подлинности пользователей при входе в систему (логин/пароль) и определять их права доступа к ресурсам (файлы, принтеры);

- хранить, создавать, изменять и удалять учетные записи пользователей, групп, компьютеров и других объектов сети;

- централизованно управлять настройками операционных систем, приложений и параметров безопасности для всех компьютеров и пользователей в домене;

- синхронизировать базы данных Active Directory между контроллерами домена для обеспечения актуальности информации и отказоустойчивости;

- взаимодействовать с системой доменных имен (DNS) для поиска контроллеров домена и других сетевых ресурсов;

- вести журналы событий, регистрацию действий пользователей и изменений в конфигурации.

Обновленный процесс авторизации в ОС изображен на рисунке 1.

В соответствии с идеологией новой модели, для работы с данными больше не предполагается использовать файлы офисных приложений, поэтому мы удалим их из модели. Всю информацию по деятельности отдела кадров предполагается сосредоточить в реляционной базе данных автоматизированной системы в защищенном исполнении (БД АСЗИ). Такая база данных должна размещаться на выделенном сервере, расположенном в обособленной серверной комнате, защищенной в соответствии с требованиями по информационной безопасности. Доступ менеджера, специалиста к базе данных возможен только после прохождения этими сотрудниками процедуры аутентификации и проверки прав пользователя. Для отображения данного факта в модель добавим подпроцесс “Выполнить вход в СУБД”, под которым будет подразумеваться аутентификация и проверка прав пользователя СУБД (рисунок 2).

Созданная модель “как будет” представлена на рисунке 4. Для работы с базой данных в компании предполагается развернуть локальную вычислительную сеть (ЛВС).

Для файлового обмена с кандидатом предусматривается использование защищенной веб-формы, уникальной для каждого кандидата, куда он будет вносить необходимые данные, которые будут шифроваться при передаче.

Таким образом, задача “структурировать полученные данные” меняется на “выгрузить полученные данные” и впоследствии будет занимать гораздо меньше времени у менеджера.

Задача “Уточнить у руководителя необходимые доступы для сотрудника” становится нерелевантной, так как в АСЗИ предварительно создаются (и согласуются с отделом ИБ) роли для каждой должности, обладающие требуемыми привилегиями.

Сроки выполнения задач на создание и отправку заявок сильно сокращаются, так как в БД АСЗИ уже имеются готовые шаблоны в соответствии с должностями. Специалисту остается внести небольшие правки в шаблон, если об этом упоминал руководитель будущего сотрудника.

После отправки заявок, сотрудники соответствующих отделов сразу получают уведомление в АСЗИ, где отображена вся необходимая информация.

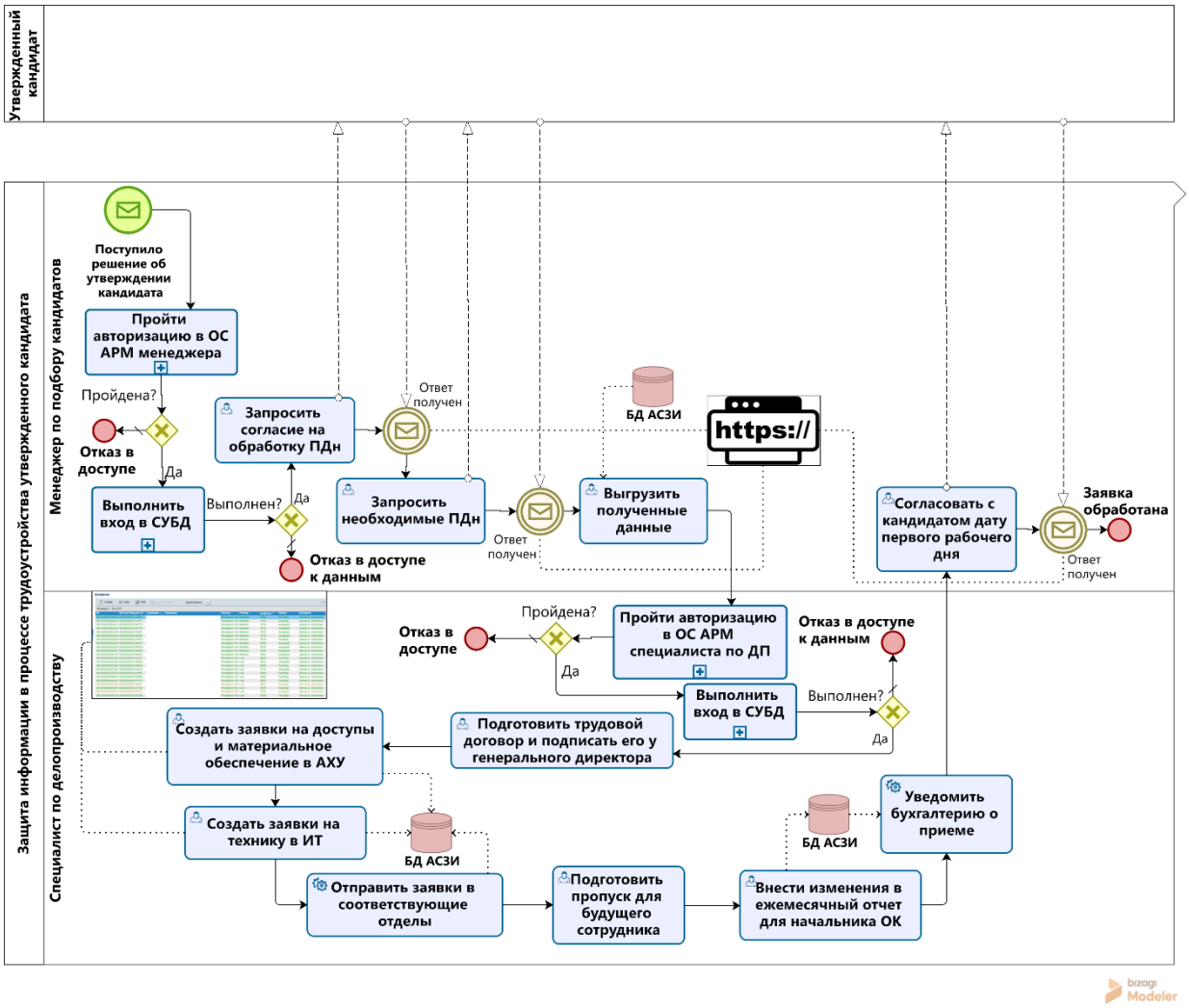


Рисунок 4 – Модель ЗИ “как будет” в процессе трудоустройства утвержденного кандидата

Выводы по проделанной работе

В результате выполнения заданий лабораторной работы были достигнуты следующие результаты:

- Построена модель “как будет” для торговой компании «Гамма» с точки зрения сотрудника ИБ;
- Построена и описана модель “как будет” для процесса учета кадров маркетинговой компании ООО “Маркетинг с умом”, а именно этап трудоустройства утвержденного кандидата;